

Security in E commerce

Monday, September 29, 2025

10:56 AM

Security in E-Commerce

The Internet and Web are increasingly vulnerable to large-scale attacks and potential system failures. Cybercriminals, often organized globally, exploit vulnerabilities to steal data, money, or intellectual property. Protecting e-commerce platforms, mobile devices, and personal information is critical for businesses and customers alike.

Online platforms carry risks because assets such as products, money, and information are all digitally accessible. Compared to physical theft, cybercrime is easier and can affect many people simultaneously. These crimes lead to higher costs for businesses and customers due to extra security measures and risk premiums.

Key Dimensions of E-commerce Security

1. Integrity

- Ensures that information displayed or transmitted online is correct and has not been altered by unauthorized parties.
- **Example:** When a customer checks their order status on Amazon, the system ensures that the quantity, price, and delivery date shown are exactly what the seller provided, without any tampering.

2. Non-repudiation

- Ensures that a party cannot deny the actions they performed online.
- **Example:** If a customer sends a payment through PayPal, neither the customer nor PayPal can later deny the transaction occurred.

3. Authenticity

- Confirms the identity of a person or entity you are dealing with online, preventing impersonation or “spoofing.”
- **Example:** Logging into your eSewa account requires a username and password to verify that it is truly you accessing the account.

4. Confidentiality

- Ensures that sensitive information is only accessible to authorized parties.
- **Example:** Credit card details entered on a Daraz checkout page are encrypted so that only the payment gateway can read them.

5. Privacy

- Enables customers to control how their personal information is used. E-commerce merchants must:
 1. Establish internal policies for using customer data.
 2. Protect this information from unauthorized access or misuse.
- **Example:** A clothing website may use your email only to send order updates and must not sell your data to third parties without consent.

6. Availability

- Ensures that the e-commerce site and its services are operational and accessible to customers without interruption.
- **Example:** Amazon ensures its website is up 24/7 so users can browse and place orders at any time.

Security Threats in E-Commerce

E-commerce platforms face numerous security threats that can harm both consumers and site operators. Understanding these threats helps businesses and users take preventive measures.

1. Malicious Code (Malware)

- Malware includes viruses, trojans, worms, ransomware, and other harmful programs that can damage a computer or steal data.
- **Prevention:** Install antivirus software, avoid suspicious links/attachments, keep software updated, and use accounts with limited permissions.
- **Example:** E-commerce sites store sensitive customer data (credit card numbers, addresses, passwords). Malware on users' computers or merchant servers can **steal or corrupt this data**, leading to financial loss and trust issues.

2. Adware

- Adware is software that displays unwanted advertisements on your computer or browser, often bundled with free or illegal software. It's sometimes called a PUP (Potentially Unwanted Program).
- **Prevention:** Avoid downloading unverified freeware, read installation prompts carefully, and use ad-blockers.
- **Example:** Adware can manipulate the user experience or **interfere with legitimate e-commerce ads and offers**, tricking customers into fake purchases or redirecting them to unsafe sites.

3. Spyware

- Spyware is malicious software installed without the user's knowledge to collect sensitive information or track online activity.
- **Prevention:** Only download apps from official stores, avoid clicking unknown links, and use trusted security software.
- **Example:** Spyware can **capture login credentials, credit card info, and browsing behavior**, directly threatening e-commerce accounts and transactions..

4. Social Engineering

- This involves manipulating humans psychologically to reveal confidential information.
- Techniques include **baiting, scareware, pretexting, phishing, and spear phishing**.
- **Prevention:** Avoid suspicious emails or attachments, use multi-factor authentication, and keep security software updated.
- **Example:** Attackers exploit human psychology to **trick customers or employees** into revealing confidential information, which can compromise online payments or internal business data..

5. Phishing

- Phishing is a type of attack that steals money or identity by tricking users into revealing personal information on fake websites.
- **Prevention:** Check URLs carefully, avoid clicking on suspicious links, report phishing attempts.
- **Example:** Fake e-commerce websites or emails pretend to be trusted platforms to **steal user credentials or payment info**, affecting both customers and merchants..

6. Hacking

- Hackers gain unauthorized access to computer systems by exploiting weaknesses in security protocols.
- **Prevention:** Use strong passwords, regular software updates, encryption, and intrusion detection systems.
- **Example:** Hackers can breach e-commerce servers to **access databases containing customer and transaction data**, disrupt website functionality, or manipulate pricing and orders..

7. Credit Card Fraud and Identity Theft

- **Credit Card Fraud:** Occurs when a thief accesses and uses a victim's credit card information.
- **Identity Theft:** Involves stealing personal information such as bank account numbers, addresses, or birth dates for financial gain.
- **Prevention:** Monitor account statements, use secure payment systems, and avoid sharing sensitive info online.
- **Example:** A cybercriminal steals card details during a fake checkout process on an e-commerce site.

8. Spoofing and Pharming

- **Spoofing:** Criminals impersonate another individual or organization to collect sensitive information.
- **Pharming:** Attackers redirect users to malicious websites resembling legitimate ones to steal credentials.
- **Prevention:** Verify website URLs, use HTTPS, and employ anti-pharming tools.
- **Example:** A user clicks a link that looks like Amazon but is a fake site designed to capture login credentials.

Vulnerabilities in E-Commerce

From a technology perspective, e-commerce has three main points of vulnerability: **Client, Server, and the Communications Pipeline**.

1. Client and Server Security

- **Client devices** (like laptops, smartphones) and **servers** (where websites and databases are hosted) can be vulnerable to attacks if not properly protected.

- **Operating System (OS) Security Enhancements:** Most modern OSs (Windows, macOS, Linux) provide automatic security updates and patches. These patches fix vulnerabilities that hackers might exploit.
 - **Example:** A Windows server hosting an online store receives an automatic security patch that protects it from a newly discovered malware attack.
- **Anti-Virus Software:** Installing reliable antivirus software is the simplest and cost-effective way to prevent malware infections. Programs like Malwarebytes, McAfee, and Norton can detect and remove malicious code, including viruses, worms, and trojans.
 - **Example:** Before opening an email attachment, the antivirus scans it and removes a hidden trojan, preventing theft of credit card details.

2. Data Transaction Security

- E-commerce transactions travel over the **public Internet**, passing through thousands of routers and servers. This exposes data to potential interception. Unlike private networks, the Internet is shared and more vulnerable.
- **Encryption:** To protect transaction data (such as credit card numbers, personal info), encryption converts the data into a secure code that can only be read by authorized parties.
 - **Example:** When a user purchases a product online, their credit card information is encrypted using SSL/TLS before it travels from their computer to the merchant server.

Key Takeaways:

- Always keep OS and applications updated to avoid known vulnerabilities.
- Install and maintain reputable antivirus software.
- Use encryption protocols (SSL/TLS) for all online transactions to secure data in transit.

Security Mechanisms in E-Commerce

E-commerce platforms require strong security mechanisms to protect data, transactions, and user privacy. The main mechanisms include:

1) Cryptography / Encryption

Encryption transforms **plain text** into **cipher text** that cannot be read by anyone except the intended recipient. It ensures secure storage and transmission of information. Encryption supports the six dimensions of e-commerce security: **Integrity, Non-repudiation, Authentication, Confidentiality, Privacy, and Availability.**

Types of Encryption:

- **Symmetric Key Cryptography**
 - Uses a **single key** for both encryption and decryption.
 - Fast, suitable for large data transfers, provides **confidentiality only**.
 - Key length: 128–256 bits.
 - **Examples:** AES, DES, 3DES
 - **Example in E-commerce:** Encrypting a bulk product catalog before storing it on the server.
- **Public Key / Asymmetric Cryptography**
 - Uses **two keys**: a public key to encrypt, a private key to decrypt.
 - Slower, suitable for small data transfers, provides **confidentiality, authenticity, and non-repudiation**.
 - Key length: 2048 bits or higher.
 - **Examples:** RSA, DSA, ECC
 - **Example in E-commerce:** Encrypting a customer's credit card info before sending it to the payment gateway.

2) Hash Functions

- A **hash function** creates a unique **digest** of a message to ensure it is not altered during transmission.
- Produces a fixed-length value, unique for each message.
- **Example in E-commerce:** Verifying that an invoice PDF has not been modified during email transmission to the customer.

3) Digital Signatures

- Ensures **authenticity** and **non-repudiation**.
- Sender encrypts the message hash with their **private key**, producing a **digital signature**.

- Only the sender possesses the private key, making it unique.
- Combined with hash functions, it is more secure than a handwritten signature.
- **Example in E-commerce:** Merchant digitally signs the electronic receipt sent to the customer to prove it came from them.

4) Authentication

- Confirms that the sender is truly who they claim to be.
- Uses **digital signatures, certificates, and PKI (Public Key Infrastructure)**.
- **Example in E-commerce:** A customer logging into an online store is authenticated using a digital certificate issued by a trusted authority.

5) Access Control

- Determines who can access networks, systems, and data.
- **Outsider controls:** Firewalls, proxy servers.
- **Insider controls:** Usernames, passwords, access codes.
- **Example in E-commerce:** Only authorized staff can access the payment processing system; other employees cannot view sensitive customer data.

6) Intrusion Detection System (IDS)

- Monitors network traffic for suspicious patterns.
- Alerts administrators if an attack is detected.
- Logs events for further investigation.
- **Example in E-commerce:** IDS detects repeated failed login attempts to a merchant's admin panel and alerts security staff.

7) Secure Sockets Layer (SSL)

- Encrypts data between a **web browser** and **web server**.
- Websites using SSL start with **https://**.
- Protects sensitive info like credit card numbers during online transactions.
- **Example in E-commerce:** A customer paying for a product sees <https://www.shop.com> and a lock icon, ensuring the connection is secure.